

SM4 密码算法的踪迹驱动 Cache 分析*

楼潇轩^{1,2}, 张帆^{1,2,3}, 黄静⁴, 赵新杰⁵, 刘会英⁶

1. 浙江大学 信息与电子工程学院, 杭州 310027
2. 密码科学技术国家重点实验室, 北京 100878
3. 浙江大学 网络空间安全研究中心, 杭州 310027
4. 61646 部队, 北京 100011
5. 北方电子设备研究所, 北京 100191
6. 装甲兵学院, 北京 100072

通信作者: 张帆, E-mail: fanzhang@zju.edu.cn

摘要: SM4 密码是一种商用分组密码算法, 是重要的国家密码行业标准. 本文研究了 SM4 密码的抗踪迹驱动 Cache 攻击能力, 并提出两种基于踪迹驱动 Cache 攻击的分析方法. 首先提出了一种基于 SM4 算法前 4 轮加密的踪迹驱动 Cache 分析方法, 对其加密前 4 轮的 Cache 泄露进行了分析. 结果表明当仅考虑 Cache 访问命中泄露时, 25 个样本可恢复完整密钥; 当同时考虑 Cache 访问命中和失效泄露时, 20 个样本可恢复密钥. 然后引入代数分析方法, 将其和踪迹驱动 Cache 分析结合进行优化, 提出了一种踪迹驱动代数 Cache 分析方法. 实验结果表明与传统踪迹驱动 Cache 分析相比, 踪迹驱动代数 Cache 分析具有离线分析简单、通用性好、分析泄露轮数多、攻击数据复杂度低等优点, 并且这一新方法只需要 10 个样本即可成功恢复密钥, 大大降低了分析所需的样本量. 本文的结果对其他典型分组密码的踪迹驱动 Cache 分析研究有很好的借鉴和参考意义.

关键词: SM4 密码; 踪迹驱动 Cache 分析; 代数旁路攻击; 踪迹驱动代数 Cache 分析

中图分类号: TP309.7 **文献标识码:** A DOI: 10.13868/j.cnki.jcr.000253

中文引用格式: 楼潇轩, 张帆, 黄静, 赵新杰, 刘会英. SM4 密码算法的踪迹驱动 Cache 分析[J]. 密码学报, 2018, 5(4): 430–441.

英文引用格式: LOU X X, ZHANG F, HUANG J, ZHAO X J, LIU H Y. Research on trace driven Cache analysis on SM4[J]. Journal of Cryptologic Research, 2018, 5(4): 430–441.

Research on Trace Driven Cache Analysis on SM4

LOU Xiao-Xuan^{1,2}, ZHANG Fan^{1,2,3}, HUANG Jing⁴, ZHAO Xin-Jie⁵, LIU Hui-Ying⁶

1. College of Information Science & Electronic Engineering, Zhejiang University, Hangzhou 310027, China
2. State Key Laboratory of Cryptology, Beijing 100878, China
3. Institute of Cyber Security Research, Zhejiang University, Hangzhou 310027, China

* 基金项目: 国家自然科学基金 (61472357, 61571063); 中央高校基本科研业务费 (2018QNA5005); 国家重点基础研究发展项目 (973 计划)(2013CB338004)

Foundation: National Natural Science Foundation of China (61472357, 61571063); the Fundamental Research Funds for the Central Universities (2018QNA5005); National Basic Research Program of China (973 Program) (2013CB338004)

收稿日期: 2018-02-26 定稿日期: 2018-04-29

4. No. 61646 Unit, Beijing 100011, China

5. Institute of North Electronic Equipment, Beijing 100191, China

6. Institute of Armored Force, Beijing 100072, China

Corresponding author: ZHANG Fan, E-mail: fanzhang@zju.edu.cn

Abstract: SM4 is a commercial block cipher which acts an important role as a national encryption standard. This paper evaluates the security of SM4 under the threat of trace driven cache attack, and proposes two analysis methods based on trace driven cache attack. First, a new trace driven cache analysis is proposed to analyze the first four rounds of SM4. Experiment results show that, when only cache misses are considered, 25 samples are required to recover the full master key; when both cache misses and hits are considered, 20 samples are sufficient for the master key recovery. Then an improved method named as trace driven algebraic cache analysis is proposed by combining traditional trace driven cache analysis with algebraic techniques. The results show that, comparing with traditional trace driven cache analysis, the new method is much simpler and more generic, and it can analyze leakages in more rounds and succeed with lower data complexity. The trace driven algebraic cache analysis only needs 10 samples to recover the master key of SM4, so that the sample size required for analysis is greatly reduced. The idea in this paper can be applied for the analysis of trace driven cache attack on other block ciphers.

Key words: SM4; trace driven Cache analysis; algebraic side-channel attacks; trace driven algebraic Cache analysis

1 引言

SM4^[1] 是中国公布的第一个商用分组密码算法, 是中国无线局域网安全标准 WAPI 的重要组成部分, 对其安全性进行分析和评估具有重要意义. 自 2006 年公开以来, 密码学者对其进行了一系列的安全性分析. 根据 SM4 的轮结构特点, 文献 [2–4] 分别给出了 14 轮的 Square 攻击、17 轮的不可能差分分析、22 轮的差分分析、23 轮的线性分析, 但攻击所需样本量和复杂度较高; 文献 [5] 给出了 SM4 在 GF(2) 和 GF(2⁸) 上的方程组描述, 并分析了利用 XL 算法进行代数攻击的复杂度; 文献 [6] 利用了 Gröbner 基和 MiniSAT 求解器对 5 轮 SM4 算法进行代数分析.

除了传统的代数攻击, 旁路攻击同样也对 SM4 密码算法的安全性造成了巨大的威胁. 在旁路攻击方面, 文献 [7] 对 SM4 抗功耗攻击能力进行了研究, 指出 5000 条功耗曲线可恢复完整密钥; 文献 [8] 应用访问驱动 Cache 攻击, 对 SM4 加密前后 4 轮进行分析, 80 个样本可成功恢复密钥; 针对 SM4 密码算法的差分故障攻击研究^[9–11] 表明最好结果为在第 29 轮进行 1 次故障注入, 将 SM4 主密钥空间降为 2^{22.11}. 随着测试计量技术及仪器的发展以及 SM4 的广泛应用进一步扩大, 旁路攻击给 SM4 密码算法带来的威胁性将越来越大. 因此, 研究 SM4 抗其他旁路攻击能力对其安全性评估十分重要. 本文主要对 SM4 密码抗踪迹驱动 Cache 攻击能力进行评估. 踪迹驱动 Cache 分析主要利用密码在微处理器实现时每次查找表的 Cache 命中和失效事件进行密钥分析. 分析方法由文献 [12] 于 2002 年首次提出, 假定攻击者可以获得每次查表的 Cache 访问命中和失效序列, 提出一种针对 DES 的 Cache 仿真攻击方法, 并给出攻击的一些防御措施; 然后文献 [13] 借鉴其分析思想对 AES 加密前 2 轮进行分析, 40 个样本可获取 94.5 比特 AES 密钥; 2007 年, 文献 [14] 利用 “Cache 失效” 踪迹对 AES 最后一轮进行分析, 使用 50 个样本即可成功恢复完整密钥; 文献 [15] 基于 “Cache 命中” 踪迹对 CLEFIA 进行了分析, 2⁴³ 个样本可恢复完整密钥; 文献 [16] 基于 Cache 不对称特性, 利用 “Cache 失效” 踪迹对 AES、CLEFIA 进行分析; 文献 [16] 提出一种改进的 AES 踪迹驱动分析方法, 并首次探讨了 ARM7 平台踪迹驱动攻击的可行性; 2012 年, 文献 [17] 首次将代数分析和踪迹驱动 Cache 分析相结合, 提出了踪迹驱动代数 Cache 分析, 并对 AES 进行了攻击应用, 可分析 AES 前 3 轮的 Cache 事件, 并将前人攻击所需的 30 个样本降低到 5 个. 2013 年, 文献 [18] 对 SM4 抗功耗代数旁路攻击能力进行了评估. 目前, 国内外尚未发现公开发表的 SM4 踪迹驱

动 Cache 攻击相关的研究成果.

本文对 SM4 密码抗踪迹驱动 Cache 攻击能力进行了系统评估, 首先提出了一种针对 SM4 密码的踪迹驱动 Cache 分析方法, 当仅考虑 Cache 访问命中信息时, 25 个样本可成功恢复完整密钥; 当同时考虑 Cache 访问命中和失效信息时, 20 个样本可恢复完整密钥. 在这基础上我们将代数分析和踪迹驱动 Cache 分析进行结合改进, 提出踪迹驱动代数 Cache 分析方法, 结果表明: 该方法具有离线分析简单、通用性好的优点; 与传统踪迹驱动 Cache 分析相比, 攻击样本量更少, 分析轮数为 8 时 10 个样本即可恢复完整主密钥.

本文章节结构如下: 第2节介绍了 SM4 密码算法的基本信息, 第3节详述了踪迹驱动 Cache 分析的细节; 第4 节介绍了优化后的踪迹驱动代数 Cache 分析方法; 第5节对本文进行总结.

2 SM4 算法描述

SM4 密码的分组和密钥长度均为 128 bit. 加密算法和密钥扩展都采用 32 轮非线性迭代结构, 加解密算法结构相同, 只是轮密钥使用顺序相反. SM4 加密算法整体结构如图1所示.

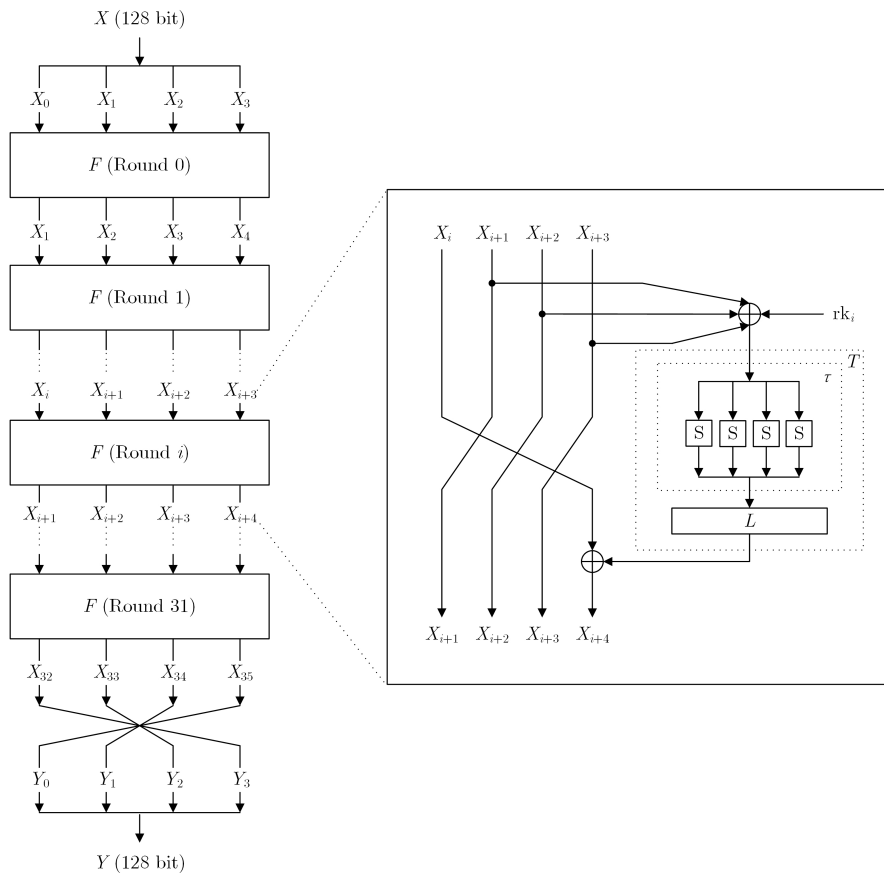


图 1 SM4 算法的加密过程
Figure 1 Encryption of SM4

为了更好地理解 SM4 算法, 我们对一些符号做如下说明.

i : 轮数 ($0 \leq i \leq 31$)

MK: 主密钥 (MK_0, MK_1, MK_2, MK_3)

rk_i : 第 i 轮使用的轮密钥 ($rk_{0,i}, rk_{1,i}, rk_{2,i}, rk_{3,i}$)

X : 第 i 轮的输入状态 $(X_i, X_{i+1}, X_{i+2}, X_{i+3})$

Y : 输出密文 (Y_0, Y_1, Y_2, Y_3)

A_i : 第 i 轮 S 盒的输入 $(a_{0,i}, a_{1,i}, a_{2,i}, a_{3,i})$

B_i : 第 i 轮 S 盒的输出 $(b_{0,i}, b_{1,i}, b_{2,i}, b_{3,i})$

C_i : 第 i 轮线性变换的输出 $(b_{0,i}, b_{1,i}, b_{2,i}, b_{3,i})$

FK: SM4 算法^[1]给出的已知系统参数 (FK_0, FK_1, FK_2, FK_3)

CK: SM4 算法^[1]给出的已知系统参数 $(CK_0, CK_1, \dots, CK_{31})$

SM4 密码算法的整体加密流程如式 (1) 所示:

$$\begin{cases} X_{i+4} = F(X_i, X_{i+1}, X_{i+2}, X_{i+3}, rk_i) = X_i \oplus T(X_{i+1} \oplus X_{i+2} \oplus X_{i+3} \oplus rk_i), i = 0, 1, \dots, 31 \\ (Y_0, Y_1, Y_2, Y_3) = R(X_{32}, X_{33}, X_{34}, X_{35}) = (X_{35}, X_{34}, X_{33}, X_{32}) \end{cases} \quad (1)$$

其中 F 是 SM4 算法的轮函数, R 是一个轮转置换函数, 其目的是将第 32 轮轮函数的输入转化为最终的加密结果: (Y_0, Y_1, Y_2, Y_3) . 合成变换 T 是由非线性变换 τ 和线性变换 L 组成的, 即 $T(\cdot) = L(\tau(\cdot))$. τ 由 4 个并行 S 盒构成, 其第 i 轮输入为 A_i , 输出为 B_i . L 以非线性变换 τ 的输出 B 作为输入, 其输出为 C_i , 如式 (2) 所示:

$$C = L(B) = B \oplus (B \lll 2) \oplus (B \lll 10) \oplus (B \lll 18) \oplus (B \lll 24) \quad (2)$$

在 SM4 算法中, 轮密钥扩展算法是非常重要的. 我们引入中间变量 $K_i \in \mathcal{F}_2^{32} (0 \leq i \leq 35)$ 来描述通过主密钥 MK 生成轮密钥 rk_i 的过程, 中间变量 (K_0, K_1, K_2, K_3) 定义如下:

$$(K_0, K_1, K_2, K_3) = (MK_0 \oplus FK_0, MK_1 \oplus FK_1, MK_2 \oplus FK_2, MK_3 \oplus FK_3) \quad (3)$$

然后通过 K_i 计算得到轮密钥 $rk_i (i = 0, 1, \dots, 31)$:

$$rk_i = K_{i+4} = K_i \oplus T'(K_{i+1} \oplus K_{i+2} \oplus K_{i+3} \oplus CK_i) \quad (4)$$

其中 FK 和 CK 均是已知系统参数. 合成变换 T' 与加密算法轮函数中的 T 相似, 只将其中的线性变换 L' 修改如下:

$$L'(B) = B \oplus (B \lll 13) \oplus (B \lll 23) \quad (5)$$

3 SM4 踪迹驱动 Cache 分析

密码运行过程中 Cache 访问命中和失效会带来时间、功率消耗、电磁辐射的差异, 且 Cache 访问命中和失效序列和密钥、S 盒查表索引之间存在很强的相关性. 基于 Cache 访问踪迹进行密钥分析的方法称之为踪迹驱动 Cache 分析. 在踪迹驱动 Cache 分析中, 攻击者一般通过功耗或电磁采集手段获取密码每次 Cache 访问命中和失效序列, 然后利用其进行密钥分析.

假设每次加密前 Cache 均被清空且加密过程中共进行 λ 次 S 盒查表操作. 每个 Cache 行有 2^6 个字节, 每个 Cache 元素的大小为 2^e 字节, S 盒的输入为 l 比特. 在本文中, 我们令 q_j 表示第 j 次 S 盒查表操作, l_j 为对应的查表索引值 $(0 \leq j \leq \lambda - 1)$. $\langle l_j \rangle$ 表示查表索引值 l_j 的最高 b 位比特 $(b = l - (\delta - e))$. U_j 和 V_j 分别是明文和主密钥的子集, $U_j \subseteq X$, $V_j \subseteq MK$. $f^j(\cdot)$ 是 l_j 关于 U_j 和 V_j 的函数.

在第二次查表操作 q_1 中, 如果是 Cache 命中, 我们就可以得出结论: 第一次查表操作的索引值 l_0 和第二次查表操作的索引值 l_1 的高 b 位是相同的:

$$\langle f(U_0, V_0) \rangle_b = \langle f(U_1, V_1) \rangle_b \quad (6)$$

由于 U_0 和 U_1 是已知的, 攻击者可以对 $V_0 \cup V_1$ 中的密钥变量进行枚举猜测来减小密钥搜索空间. 如果满足式 (6), 则表明可能是正确的密钥候选值组合. 经多个样本排除分析后, 获得正确候选值组合. 如果第 2 次 S 盒查表发生 Cache 访问失效, 表明 l_0 和 l_1 的高 b 位是不相等的, 同样可通过式 (7) 进行密钥排除分析.

$$\langle f(U_0, V_0) \rangle_b \neq \langle f(U_1, V_1) \rangle_b \quad (7)$$

在前面分析得到正确部分密钥候选值的基础上, 基于同样方法对后续 S 盒查表访问命中和失效序列进行分析, 直到主密钥 MK 可在有限时间复杂度内暴力破解.

3.1 第 1 轮分析

前文中已经定义过了 $A_i = (a_{0,i}, a_{1,i}, a_{2,i}, a_{3,i})$ 是第 i 轮加密中四个 S 盒的输入, 即每轮加密过程中均有 4 次查表操作, $\langle a_{j,i} \rangle$ 表示第 i 轮中的第 j 次查表操作 ($i = 0, 1, 2, 3; j = 0, 1, 2, 3$). 在 SM4 算法的第一轮中, 总共有 4 次 S 盒查表操作, 这 4 次的输入被记为 $(a_{0,0}, a_{1,0}, a_{2,0}, a_{3,0})$:

$$\begin{cases} a_{0,0} = X_{0,1} \oplus X_{0,2} \oplus X_{0,3} \oplus \text{rk}_{0,0} \\ a_{1,0} = X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \oplus \text{rk}_{1,0} \\ a_{2,0} = X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \oplus \text{rk}_{2,0} \\ a_{3,0} = X_{3,1} \oplus X_{3,2} \oplus X_{3,3} \oplus \text{rk}_{3,0} \end{cases} \quad (8)$$

在式 (8) 中, $X_{j,k}$ 是第 i 轮部分输入 X_k ($i+1 \leq k \leq i+3$) 的第 j 个元素, 每个元素均为 8 比特.

在第一轮的第二次查表操作 q_1 中, 如果发生 Cache 命中, q_0 和 q_1 的查表索引值将是相同的, 因此我们可以得到:

$$\langle a_{0,0} \rangle = \langle a_{1,0} \rangle \implies \langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle = \langle X_{0,1} \oplus X_{0,2} \oplus X_{0,3} \oplus X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \rangle \quad (9)$$

如果发生 Cache 失效, 则有:

$$\langle a_{0,0} \rangle \neq \langle a_{1,0} \rangle \implies \langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle \neq \langle X_{0,1} \oplus X_{0,2} \oplus X_{0,3} \oplus X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \rangle \quad (10)$$

当 Cache 访问命中时, 经式 (9) 分析可得到 $\langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle$ 的可能值集合; Cache 访问失效时, 经式 (10) 分析可得 $\langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle$ 的不可能值集合. 经多样本排除分析后, 可得到唯一的 $\langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle$ 值.

对于第 3 次查表操作 q_2 , 如果它是 Cache 命中, 则 q_2 的查表索引值和 q_0 或 q_1 的相同, 所以可以得到:

$$\begin{aligned} \langle l_{2,0} \rangle \in \{ \langle a_{0,0} \rangle, \langle a_{1,0} \rangle \} \implies \langle \text{rk}_{0,0} \oplus \text{rk}_{2,0} \rangle \in \{ \langle X_{0,1} \oplus X_{0,2} \oplus X_{0,3} \oplus X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \rangle, \\ \langle X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \oplus X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \oplus \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle \} \end{aligned} \quad (11)$$

如果是 Cache 失效, 则有:

$$\begin{aligned} \langle l_{2,0} \rangle \notin \{ \langle l_{0,0} \rangle, \langle l_{1,0} \rangle \} \implies \langle \text{rk}_{0,0} \oplus \text{rk}_{2,0} \rangle \notin \{ \langle X_{0,1} \oplus X_{0,2} \oplus X_{0,3} \oplus X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \rangle, \\ \langle X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \oplus X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \oplus \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle \} \end{aligned} \quad (12)$$

在第 2 次 S 盒查表 q_1 分析获取 $\langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle$ 的基础上, 通过式 (11)、(12) 经多样本分析求交集后可得到唯一的 $\langle \text{rk}_{0,0} \oplus \text{rk}_{2,0} \rangle$. 第 4 次 S 盒查表分析方法与前面相同. 通过对第 1 轮 4 次查 S 盒的 Cache 命中和失效信息进行多样本排除分析, 可最终获得 $\langle \text{rk}_{0,0} \oplus \text{rk}_{1,0} \rangle$, $\langle \text{rk}_{0,0} \oplus \text{rk}_{2,0} \rangle$ 和 $\langle \text{rk}_{0,0} \oplus \text{rk}_{3,0} \rangle$ 的值.

3.2 第 2 轮分析

与第 1 轮类似, 第 2 轮的 S 盒输入可以表示如下:

$$\begin{cases} a_{0,1} = X_{0,2} \oplus X_{0,3} \oplus X_{0,4} \oplus rk_{0,1} \\ a_{1,1} = X_{1,2} \oplus X_{1,3} \oplus X_{1,4} \oplus rk_{1,1} \\ a_{2,1} = X_{2,2} \oplus X_{2,3} \oplus X_{2,4} \oplus rk_{2,1} \\ a_{3,1} = X_{3,2} \oplus X_{3,3} \oplus X_{3,4} \oplus rk_{3,1} \end{cases} \quad (13)$$

对于第 2 轮的第 1 次查表操作, 即整个过程的第 5 次查表 q_4 , 如果发生 Cache 命中, 则有:

$$\begin{aligned} a_{0,1} &\in \{\langle a_{0,0} \rangle, \langle a_{1,0} \rangle, \langle a_{2,0} \rangle, \langle a_{3,0} \rangle\} \\ &\implies \langle rk_{0,0} \oplus rk_{0,1} \rangle \in \{\langle X_{0,1} \oplus X_{0,4} \rangle, \\ &\quad \langle X_{0,2} \oplus X_{0,3} \oplus X_{0,4} \oplus X_{1,1} \oplus X_{1,2} \oplus X_{1,3} \oplus rk_{1,0} \oplus rk_{0,0} \rangle, \\ &\quad \langle X_{0,2} \oplus X_{0,3} \oplus X_{0,4} \oplus X_{2,1} \oplus X_{2,2} \oplus X_{2,3} \oplus rk_{2,0} \oplus rk_{0,0} \rangle, \\ &\quad \langle X_{0,2} \oplus X_{0,3} \oplus X_{0,4} \oplus X_{3,1} \oplus X_{3,2} \oplus X_{3,3} \oplus rk_{3,0} \oplus rk_{0,0} \rangle\} \end{aligned} \quad (14)$$

由于 $\langle rk_{0,0} \oplus rk_{1,0} \rangle$, $\langle rk_{0,0} \oplus rk_{2,0} \rangle$ 和 $\langle rk_{0,0} \oplus rk_{3,0} \rangle$ 的值已知, 利用式 (13) 和式 (14) 经多样本分析可得到唯一的 $rk_{0,0}$, $rk_{1,0}$, $rk_{2,0}$, $rk_{3,0}$ 和 $\langle rk_{0,1} \rangle$ 值.

对于第 2 轮第 2 次 S 盒查表, 利用前面恢复的各项参数, 经过多样本分析后可以获得唯一的 $\langle rk_{1,1} \rangle$ 值. 这样, 通过分析 4 次 S 盒 Cache 访问命中和失效信息, $rk_{0,0}$, $rk_{1,0}$, $rk_{2,0}$, $rk_{3,0}$ 和 $\langle rk_{0,1} \rangle$, $\langle rk_{1,1} \rangle$, $\langle rk_{2,1} \rangle$, $\langle rk_{3,1} \rangle$ 可被依次恢复.

3.3 主密钥恢复

利用相同的分析方法, 对加密第 3 轮进行分析, 可依次恢复 $rk_{0,1}$, $rk_{1,1}$, $rk_{2,1}$, $rk_{3,1}$, $\langle rk_{0,2} \rangle$, $\langle rk_{1,2} \rangle$, $\langle rk_{2,2} \rangle$ 和 $\langle rk_{3,2} \rangle$. 对加密第 4 轮进行分析, 可依次恢复 $rk_{0,2}$, $rk_{1,2}$, $rk_{2,2}$, $rk_{3,2}$, $\langle rk_{0,3} \rangle$, $\langle rk_{1,3} \rangle$, $\langle rk_{2,3} \rangle$, $\langle rk_{3,3} \rangle$. 经前 4 轮分析后, 前 3 轮密钥 rk_0 , rk_1 和 rk_2 可成功恢复, 第 4 轮密钥中的 $\langle rk_{0,3} \rangle$, $\langle rk_{1,3} \rangle$, $\langle rk_{2,3} \rangle$, $\langle rk_{3,3} \rangle$ 可被依次恢复. 剩余的未知密钥可以通过较少次数的暴力破解获取, 从而恢复第 4 轮的轮密钥 rk_3 , 然后根据密钥扩展算法可恢复主密钥.

3.4 攻击实验及分析

攻击中, 将 SM4 算法实现在 32 位 ARM 微处理器 NXP LPC2124 中, SM4 实现采用的 S 盒大小为 256 B, 每个元素大小为 1 B, 每个 Cache 行的大小为 16 B, $b = 4$. Cache 命中和失效事件通过电磁辐射采集和分析进行推断. 在攻击实验中, 示波器采用泰克 4104, 电磁探头采用埃姆克近场探头组 RF2, 电磁预处理采用 PA303N 前置放大器. 图 2 展示了某样本中 SM4 密码查找表执行 6 次 Cache 访问的电磁轨迹. 可以看出 Cache 失效对应的电磁轨迹峰值较大, 命中则相对较低, 这与我们的预期相符.

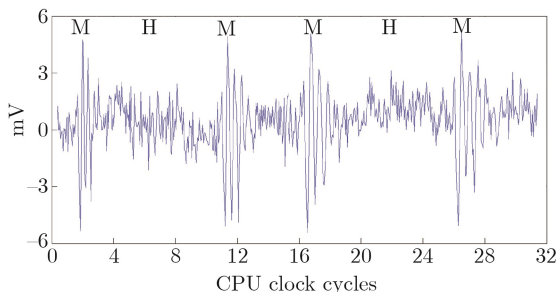


图 2 电磁曲线样本
Figure 2 Electromagnetic trace

下面给出不同轮 Cache 访问泄露分析中样本量同扩展密钥搜索空间的关系.

第 1 轮分析中, MK_0 的搜索空间和样本量关系如图3所示. 根据图3, 当仅基于 Cache 失效信息时, 35 个样本可将 rk_0 的搜索空间降低到 2^{16} ; 当考虑 Cache 命中和失效信息时, 30 个样本可将 rk_0 的搜索空间降低到 2^{16} .

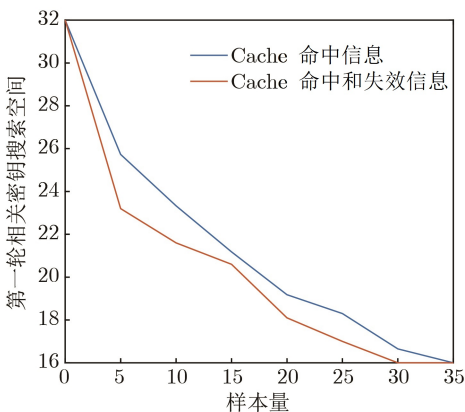


图 3 第 1 轮分析中 MK_0 剩余搜索空间和样本量关系
Figure 3 Search space and sample size when analyzing MK_0 in first round

第 2 轮分析中, rk_0 , rk_1 的剩余搜索空间和样本量关系如图4所示. 从图中我们可以得到, 当仅考虑 Cache 失效信息, 35 个样本可将 rk_0 , rk_1 的密钥搜索空间降至 2^{16} ; 当同时考虑 Cache 命中和失效信息时, 25 个样本可将密钥搜索空间降至 2^{16} .

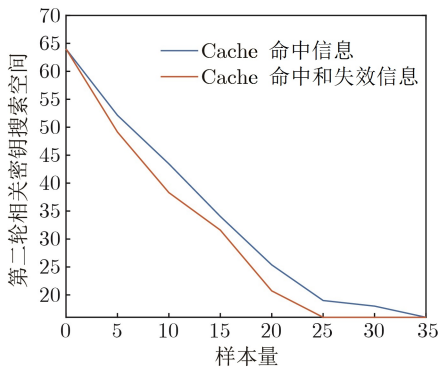


图 4 第 2 轮分析中 rk_0 , rk_1 剩余搜索空间和样本量关系
Figure 4 Search space and sample size when analyzing rk_0 and rk_1 in first two rounds

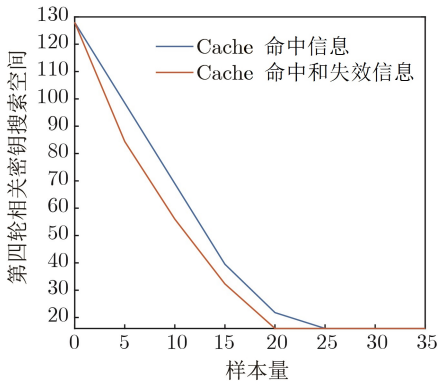


图 5 第 4 轮分析中主密钥搜索空间和样本量关系
Figure 5 Relationship between sample size and search space in first four rounds

图5为第 4 轮分析中, 主密钥 (rk_0 , rk_1 , rk_2 , rk_3) 搜索空间同样本量的关系. 根据图中结果, 当仅考虑 Cache 访问失效信息, 25 个样本可将密钥搜索空间降至 2^{16} . 根据 SM4 密钥扩展算法, 已知前 4 轮密钥可推导出主密钥, 恢复完整密钥共需 25 个样本; 当同时考虑 Cache 命中和失效信息时, 20 个样本可成功恢复 SM4 主密钥.

4 SM4 踪迹驱动代数 Cache 分析

4.1 踪迹驱动 Cache 攻击优化

在上一节中提出的传统踪迹驱动 Cache 分析虽然可以有效破解 SM4 密码, 但其存在以下几点不足: 一是攻击过程繁琐并且分析轮数受限. 由于分析过程中对第 r 轮进行分析是在前 $(r-1)$ 轮分析基础上进行, 如果前面 $(r-1)$ 轮密钥剩余搜索空间过大, 将会导致第 r 轮分析复杂度过高. 二是其采用“分而治之”的思想对密钥进行分块恢复, 未能充分体现密码算法结构各个轮密钥之间的相关性.

本节将代数攻击和踪迹驱动 Cache 分析结合, 给出了一种新的分析方法, 称为踪迹驱动代数 Cache 分析方法, 攻击分三个阶段: 密码代数方程组构建、Cache 访问踪迹采集及表示、基于代数方程组求解的密钥恢复. 当密码算法代数方程组和 Cache 访问踪迹信息等价代数方程组进行联立后, 对联立方程组进行求解, 进而恢复密钥. 目前, 典型的代数方程组求解方法主要包括线性化方法 (直接线性化 XL、扩展线性化 XSL)、Gröbner 基^[19]以及基于可满足性问题求解 (使用 zChaff^[20]、Minisat^[21]以及 CryptoMinisat^[22]等求解器). 本文中基于 CryptoMinisat 进行密钥求解.

4.2 踪迹驱动代数 Cache 分析的实现

4.2.1 构建 SM4 算法代数方程组

S 盒是 SM4 算法中唯一的非线性部件, 如何有效构建 S 盒的代数方程组是 SM4 代数方程组构建的关键部分. 从 S 盒设计角度出发, S 盒的输出 B 均可以表示 GF(2) 上以 S 盒输入 A 为变元的布尔函数.

对于 SM4 算法而言, S 盒的输入和输出均是 8 比特的, $s = t = 8$. S 盒可以表示为关于输入 A 和输出变量 B 的 8 个高阶布尔代数方程. 假定 (X_0, X_1, X_2, X_3) 是 SM4 算法的 128 比特输入, $(X_{32}, X_{33}, X_{34}, X_{35})$ 是对应的输出. SM4 加密算法可转化为如下布尔方程组:

$$\begin{cases} X_{i+1,m} \oplus X_{i+2,m} \oplus X_{i+3,m} \oplus \text{RK}_{i,m} \oplus W_{i,m} = 0 \\ V_i \oplus \tau[W_i] = 0 \\ U_{i,m} \oplus L(V_i)_m = 0 \\ U_{i,m} \oplus X_{i,m} \oplus X_{i+4,m} = 0 \end{cases} \quad (15)$$

其中, $i = 0, \dots, 31, m = 0, \dots, 31, t = 0, \dots, 3$. 方程式中新增的变量说明附于表1.

表 1 新增变量说明
Table 1 Description of new variables

新增变量	描述
$K_{i,m}$	第 i 轮轮密钥的第 m 个比特变量
$W_{i,m}$	第 i 轮 S 盒代换输入的第 m 个比特变量
$V_{i,m}$	第 i 轮 S 盒代换输出的第 m 个比特变量
$U_{i,m}$	第 i 轮线性变换输出的第 m 个比特变量
$X_{i+4,m}$	第 i 轮加密轮函数输出的第 m 个比特变量

基于以上方程组构建方法, 可以得到 4352 个 GF(2) 上的方程. 其中包括 1024 个非线性方程, 3328 个线性方程, 5248 个变量. 同样的方法可以构建密钥扩展的 GF(2) 的方程组, 包含 4096 个方程, 其中非线性方程为 1024 个, 线性方程为 3072 个; 共包含 4224 个变量, 其中密钥变量为 1152 个, 中间变量为 3072 个. 对于 SM4 的完整 32 轮加密, 可以得到 9472 个方程, 共包含 9472 个变量. 事实上, 在代数旁路攻击过程中, 仅需建立部分轮对应的代数方程组即可.

4.2.2 Cache 命中/失效信息的代数方程组表达

通过收集到的 Cache 踪迹曲线可以推断得到 Cache 的访问行为序列, 并可以进一步将这些信息转换为代数方程组. 图6给出了 5 个样本加密前 8 轮查表访问 Cache 命中和失效序列, 图中灰色的格子表示一

次 Cache 失效, 白色格子表示一次 Cache 命中, 横坐标表示 S 盒查表操作序号, 纵坐标表示样本序号.

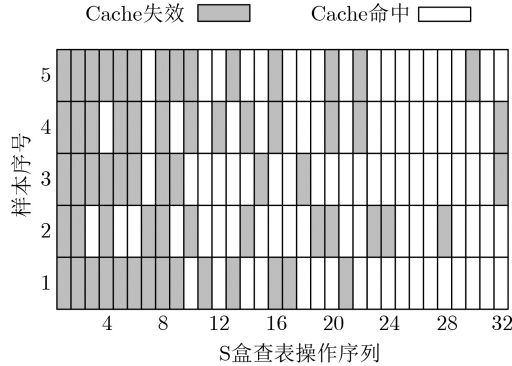


图 6 5 个样本加密前 8 轮的 Cache 访问命中和失效序列
Figure 6 Sequence of Cache hits and misses in first eight rounds with 5 samples

从图中可看出, 4 轮以后, 即 16 次查表操作以后, 随着访问 Cache 次数的增加, 发生 Cache 访问命中的概率逐渐增加. 我们以图中第 2 个样本前 8 轮 Cache 访问踪迹 T_2 为例进行分析. 由于 T_2 中第 8 次查表操作 q_7 发生 Cache 访问失效, 则 $\langle l_7 \rangle$ 的不可能值集合可推断如下:

$$\overline{G_7} = \{\langle l_0 \rangle, \langle l_1 \rangle, \langle l_3 \rangle, \langle l_6 \rangle\} \quad (16)$$

T_2 中第 9 次查表操作 q_8 发生 Cache 访问命中, 则 $\langle l_8 \rangle$ 的可能值集合可推断如下:

$$G_8 = \{\langle l_0 \rangle, \langle l_1 \rangle, \langle l_3 \rangle, \langle l_6 \rangle, \langle l_7 \rangle\} \quad (17)$$

根据 $\langle l_i \rangle$ 的可能值集合与不可能值集合, 我们可以获取前 i 次 Cache 访问中每次索引值之间的代数关系, 进而构建 Cache 访问信息的代数方程组.

4.2.3 主密钥恢复

本文主要选取 SAT 求解器 CryptMinisat 进行密钥恢复. 利用 CryptMinisat 进行方程组求解, 首先需要将代数方程组转化为等价的 CNF(合取范式). 该过程主要包括降幂操作和线性方程 CNF 转化两个步骤.

(1) 降幂操作. 对于方程组中每 1 个次数 d 大于 1 的单项式, 引入 1 个变量和 $d+1$ 个 CNF 子句, 用变量替换高次单项式. 这样, 代数方程组就转化为关于未知变量和常量的线性方程组.

(2) 对于长度为 L 的线性方程, 将其转化为 2^{L-1} 个 CNF 子句的合取. 其中, 每 1 个子句分别为 m 个 (m 为小于或等于 L 的奇数) 变量取反的析取. 由于 CryptMinisat 可以自动将线性方程进行 CNF 转化, 该操作无需手动进行.

基于上述方法, 每个 S 盒经转化后可得到 254 个 CNF 子句. 当考虑密钥扩展时, 每轮加密需引入 1336 个 CNF 子句, 32 轮共生成 43 009 个 CNF 子句. 攻击中, 只需建立加密部分轮代数方程. 当 CNF 转化完成后, 剩余工作是根据 CNF 生成 CryptMinisat 所需的脚本文件, 调用求解器进行密钥恢复, 具体可参考文献 [22]. 攻击中, 我们在普通 PC 机器上 (CPU 为 Pentium(R) Dual-Core E5400 2.7 GHZ, 内存 2G), 利用 CryptMinisat(版本号 2.9.4) 进行密钥恢复. Cache 行的大小及 S 盒查找表实现同 3.4 节, 故 $N_c = 16$, $b = 4$.

4.2.4 攻击实验及分析

基础实验中, 假定加密过程中 Cache 访问命中和失效踪迹信息都能准确获取并用于分析. 为规范攻击成功率, 当求解时间超过 24 小时, 视为攻击失败.

图7给出 Cache 分析轮数为 8, 样本量为 10 条件下 SM4 密钥求解时间分布. 从图中可以看出, 密钥求解时间大致呈指数分布, 大部分的密钥求解均可在 12 小时内完成.

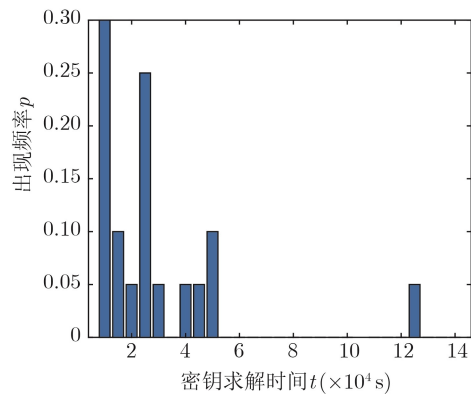


图 7 SM4 前 8 轮分析密钥求解时间分布
Figure 7 Solving time distribution of SM4 when analyzing first 8 rounds

图8给出了样本量为 20, 不同 Cache 分析轮数条件下攻击所需平均时间. 从图中可以看出, 样本量固定条件下, 攻击所需时间在一定轮数范围内随着轮数增加而减小; 当超出轮数范围后, 密钥求解时间随着分析轮数增加反而增大.

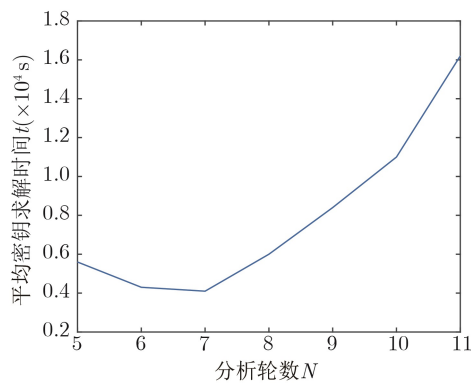


图 8 样本量固定时不同分析轮数下的密钥求解时间
Figure 8 Average solving time distribution when analyzing different rounds with fixed number of samples

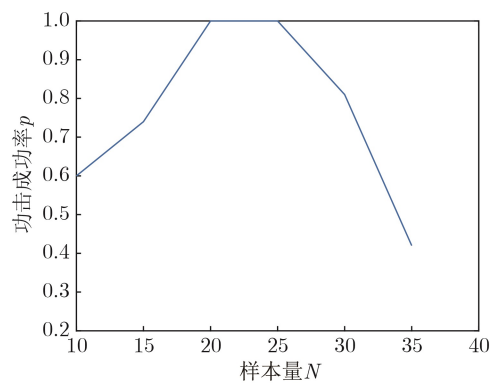


图 9 分析轮数固定时不同样本量条件下的攻击成功率
Figure 9 The attack success rate when analyzing the same round with different number of samples

图9给出分析轮数固定为 5 时, 不同样本量条件下的攻击成功率. 可以看出, 分析轮数固定条件下, 攻击成功率并非一直随着样本量增加而提高, 当样本量超过一定范围后, 攻击成功率会急剧下降. 这是由于样本量增加的同时方程组规模也在增加, 求解难度逐渐变大.

通过上述结果, 可以看出攻击需在分析轮数和样本量之间进行权衡考虑. 当前实际攻击实验中, 分析轮数为 8 轮, 样本量为 10 时攻击效果最佳.

5 结论

本文对 SM4 密码抗踪迹驱动 Cache 分析能力进行了评估. 首先基于传统的踪迹驱动 Cache 分析对 SM4 进行了安全性分析, 结果表明通过分析前 4 轮 Cache 访问旁路泄露, 至少 20 个样本可恢复 SM4 密

码密钥。为降低攻击复杂度,将代数攻击和踪迹驱动 Cache 分析相结合,利用踪迹驱动代数 Cache 分析方法对 SM4 进行了攻击应用,结果表明提出方法可分析前 8 轮 Cache 访问旁路泄露,10 个样本即可恢复 SM4 密码完整密钥。本文研究思路和方法可为针对 ARIA、Camellia 等其它典型分组密码抗踪迹驱动代数 Cache 攻击安全性评估提供借鉴和参考。

References

- [1] Office of security commercial code administration[OL]. Dec. 2017.
<http://www.osscca.gov.cn/UpFile/200622026423297990.pdf>.
- [2] ZHONG M F, HU Y P, CHEN J. Square attack on the 14-round block cipher SMS4[J]. Journal of Xidian University, 2008, 35(1): 105–109.
钟名富, 胡予濮, 陈杰. 分组加密算法 SMS4 的 14 轮 Square 攻击 [J]. 西安电子科技大学学报, 2008, 35(1): 105–109.
- [3] CHEN J, HU Y P, ZHANG Y Y. Impossible differential attack on the 17-round block cipher SMS4[J]. Journal of Xidian University, 2008, 35(3): 455–458.
陈杰, 胡予濮, 张跃宇. 用不可能差分法分析 17 轮 SMS4 算法 [J]. 西安电子科技大学学报, 2008, 35(3): 455–458.
- [4] ZHANG M L, LIU J M, WANG X M. Differential attack on 22-round SMS4 block cipher[J]. Acta Scientiarum Naturalium Universitatis Sunyatseni, 2010, 49 (2): 43–47.
张美玲, 刘景美, 王新梅. 22-轮 SMS4 的差分分析 [J]. 中山大学学报自然科学版, 2010, 49 (2): 43–47.
- [5] JI W, HU L, OU H W. Algebraic attack to SMS4 and the comparison with AES[C]. In: 2009 International Symposium on Information Assurance and Security. Xi'an, China, 2009: 662–665. [DOI: 10.1109/IAS.2009.171]
- [6] ERICKSON J, DING J T, CHRISTENSEN C. Algebraic cryptanalysis of SMS4: Gröbner basis attack and SAT attack compared[C]. In: Information, Security and Cryptology—ICISC 2009. Springer Berlin Heidelberg, 2009: 73–86. [DOI: 10.1007/978-3-642-14423-3_6]
- [7] BAI X F, GUO L, XU Y H, et al. Research on differential power analysis attack on SMS4 algorithm[J]. Journal of Chinese Computer Systems, 2009, (3): 541–544.
白雪飞, 郭立, 徐艳华, 等. SMS4 密码算法的差分功耗分析攻击研究 [J]. 小型微型计算机系统, 2009, (3): 541–544.
- [8] ZHAO X J, WANG T, ZHENG Y Y. Cache timing attack on SMS4[J]. Journal on Communications, 2010, 31(6): 89–98. [DOI: 1000-436X(2010)06-0089-10]
赵新杰, 王韬, 郑媛媛. 针对 SMS4 密码算法的 Cache 计时攻击 [J]. 通信学报, 2010, 31(6): 89–98. [DOI: 1000-436X(2010)06-0089-10]
- [9] ZHANG L, WU W L. Differential fault analysis on SMS4[J]. Chinese Journal of Computers, 2006, 29(9): 1596–1602.
张蕾, 吴文玲. SMS4 密码算法的差分故障攻击 [J]. 计算机学报, 2006, 29(9): 1596–1602.
- [10] LI W, GU D W. Differential fault analysis on the SMS4 cipher by inducing faults to the key schedule[J]. Journal on Communications, 2008, 29(10): 135–142. [DOI: 1000-436X(2008)10-0135-08]
李玮, 谷大武. 基于密钥编排故障的 SMS4 算法的差分故障分析 [J]. 通信学报, 2008, 29(10): 135–142. [DOI: 1000-436X(2008)10-0135-08]
- [11] LI R L, SUN B, LI C, et al. Differential fault analysis on SMS4 using a single fault. In: Information Processing Letters, 2011, 111(4): 156–163. [DOI: 10.1016/j.ipl.2010.11.011]
- [12] PAGE D. Theoretical use of cache memory as a cryptanalytic side-channel[OL]. IACR Cryptology ePrint Archive, 2002: 2002/169.
- [13] ACIÇMEZ O, KOÇÇK. Trace-driven cache attacks on AES[C]. In: Information and Communications Security—ICICS 2006. Springer Berlin Heidelberg, 2006: 112–121. [DOI: 10.1007/11935308_9]
- [14] BONNEAU J. Robust final-round cache-trace attacks against AES[OL]. IACR Cryptology ePrint Archive, 2006: 2006/374.
- [15] REBEIRO C, MUKHOPADHYAY D. Differential cache trace attack against CLEFIA[OL]. IACR Cryptology ePrint Archive, 2010: 2010/012.
- [16] ZHAO X J, GUO S Z, WANG T, et al. Improved cache trace driven attack on AES and CLEFIA[J]. Journal on Communications, 2011, 32(8): 101–110. [DOI: 1000-436X(2011)08-0101-10]
赵新杰, 郭世泽, 王韬, 等. 针对 AES 和 CLEFIA 的改进 Cache 踪迹驱动攻击 [J]. 通信学报, 2011, 32(8): 101–110. [DOI: 1000-436X(2011)08-0101-10]
- [17] ZHAO X J, ZHANG F, GUO S Z, et al. MDASCA: An enhanced algebraic side-channel attack for error tolerance and new leakage model exploitation[C]. In: Constructive Side-Channel Analysis and Secure Design—COSADE 2012. Springer Berlin Heidelberg, 2012: 231–248. [DOI: 10.1007/978-3-642-29912-4_17].
- [18] LIU H Y, ZHAO X J, WANG T, et al. Research on Hamming weight-based algebraic side-channel attacks on

SMS4[J]. Chinese Journal of Computers, 2013, 36(6): 1183–1193.
刘会英, 赵新杰, 王韬, 等. 基于汉明重的 SMS4 密码代数旁路攻击研究 [J]. 计算机学报, 2013, 36(6): 1183–1193.

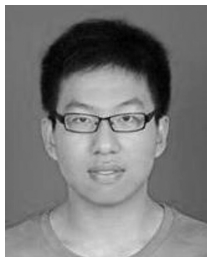
[19] BECKER T, WEISPFENNING V, ADAMS W W, et al. Gröbner bases: A computational approach to commutative algebra[J]. Bulletin of the American Mathematical Society, 1996, 33: 477–482. [DOI: 10.1090/S0273-0979-96-00674-X].

[20] FU Z H, MARHAJAN Y, MALIK S. zChaff SAT solver[C]. In: Group, Princeton University. <http://www.princeton.edu/~chaff/zchaff.html>, 2004.

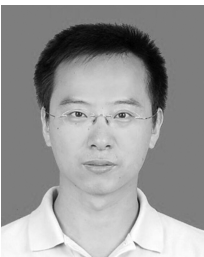
[21] EÉN N, SÖRENSON N. Minisat 2.0. An open-source SAT solver package[OL]. <http://www.cs.chalmers.se/Cs/Research/FormalMethods/MiniSat/>. Dec. 2017.

[22] SOOS M, NOHL K, CASTELLUCCIA C. Extending SAT solvers to cryptographic problems[C]. In: Theory and Applications of Satisfiability Testing—SAT 2009. Springer Berlin Heidelberg, 2009: 244–257. [DOI: 10.1007/978-3-642-02777-2_24].

作者信息



楼潇轩 (1995–), 浙江金华人, 硕士生在读. 主要研究领域为计算机系统安全与密码学.
xiaoxuanlou@zju.edu.cn



张帆 (1978–), 浙江杭州人, 副教授, 博士生导师. 主要研究领域为网络空间安全与密码学.
fanzhang@zju.edu.cn



黄静 (1983–), 四川南充人, 助理工程师. 主要研究领域为卫星网络与信息安全.
huangjing2013@tsinghua.org.cn



赵新杰 (1986–), 河南开封人, 博士, 高级工程师. 主要研究领域为网络空间安全与密码学.
zhaoxinjieem@163.com



刘会英 (1984–), 湖北黄石人, 博士, 讲师. 主要研究领域为密码组合旁路分析.
lhy_fengling@126.com